

VULNERABILITY MANAGEMENT PROGRAM

Lab Assessment Report

Including: SOPs · Risk Exceptions · Executive Brief

Prepared by:	Kendall Montero
Classification:	Confidential — Internal Use Only
Date:	April 23, 2026
Tool:	Qualys VMDR — Community Edition
Environment:	Isolated lab network — VMware (192.168.75.0/24)
Version:	1.0 — Final

Contents

- 1. Executive Summary.....2
- 2. Scope & Environment.....3
 - 2.1 Lab Setup — Windows LPE Workshop3
- 3. Methodology3
 - 3.1 Qualys Configuration4
- 4. Scan Results — Phase Comparison4
 - 4.1 Ubuntu 24.04 LTS (192.168.75.132)4
 - 4.2 Windows Hosts Combined (192.168.75.129 + .130)4
- 5. Key Findings & Remediation5
 - 5.1 Remediated Findings (Verified by Rescan)5
 - 5.2 VMDR Dashboard — Remediation Metrics5
- 6. Residual Risk & Recommendations6

7. SOP: Vulnerability Management Scanning Process	7
7.1 Purpose	7
7.2 Scope	7
7.3 Prerequisites	7
7.4 Procedure.....	7
Step 1 — Pre-Scan Validation.....	7
Step 2 — Launch Scan	7
Step 3 — Monitor & Validate	7
Step 4 — Generate & Distribute Report	7
Step 5 — Remediation Tracking	7
7.5 SLA Targets	8
8. Risk Exception Register	8
Exception #001 — EOL Operating System: Windows 10 22H2	8
Exception #002 — AMD Processor Hardware Vulnerability (RYZENFALL/MASTERKEY)	8
Exception #003 — OpenSSH CVEs Pending Vendor Patch (Canonical)	9
9. Executive Brief: Why Vulnerability Management Matters.....	10
9.1 The Business Case	10
9.2 Why Authenticated Scanning is Non-Negotiable	10
9.3 Framework Alignment	10
9.4 VM Program Maturity Model	10
10. Conclusion	11

1. Executive Summary

This report documents a full Vulnerability Management (VM) lifecycle exercise conducted on an isolated lab environment comprising three virtual machines: one Ubuntu 24.04 LTS server and two Windows hosts (Windows 10 22H2 and Windows Server 2019). The exercise was performed using Qualys VMDR Community Edition and followed a structured three-phase approach: unauthenticated scanning, authenticated scanning, and post-hardening verification scanning.

The primary objective was to demonstrate the value of credentialed scanning, execute targeted hardening actions based on confirmed findings, and verify remediation effectiveness through a subsequent scan — replicating the workflow expected in enterprise vulnerability management programs.

Host	Unauthenticated	Authenticated	Post-Hardening
Ubuntu 24.04 (192.168.75.132)	18	90	89
Windows 10 22H2 (192.168.75.129)	~27	~353	120
Windows Server 2019 (192.168.75.130)	~27	~353	87
TOTAL (Windows combined)	54	706	587 (–17%)

Key outcome: Authenticated scanning revealed 652 additional vulnerabilities on Windows hosts that were invisible to unauthenticated scans — a 1,207% increase in detection. Post-hardening scanning confirmed elimination of critical findings including SMBv2 signing, SSH SHA-1 deprecated algorithms, Autorun misconfigurations, and the majority of missing Windows security patches.

2. Scope & Environment

The assessment was conducted entirely within an isolated VMware-based lab network. No production systems, external networks, or internet-facing assets were involved. All hosts reside on the 192.168.75.0/24 subnet with no external routing.

Hostname	IP Address	Operating System	Role in Lab	Scanner
ubuntu-server	192.168.75.132	Ubuntu 24.04.4 LTS	Linux target	KmoVulnScanLab
DESKTOP-VIUR4AO	192.168.75.129	Windows 10 Pro 22H2	Win target + LPE workshop	KmoVulnScanLab
WIN-RGJC4DU4QTF2	192.168.75.130	Windows Server 2019 Std Eval	Windows Server target	KmoVulnScanLab
Qualys Scanner Appliance	192.168.75.133	Ubuntu / Tiny Core Linux	Scanner appliance	N/A

2.1 Lab Setup — Windows LPE Workshop

The Windows 10 22H2 host was intentionally configured with the Local Privilege Escalation (LPE) Workshop setup script, which introduced the following vulnerable services to simulate real-world misconfigurations commonly found in enterprise environments:

- Unquoted Service Path (unquotedsvc) — service binary path without quotes
- DACL Service (daclsvc) — weak DACL permissions on service executable
- File Permissions Service — writable service binary by unprivileged users
- Insecure Registry Service (regsvc) — registry key modifiable by standard users
- DLL Hijack Service — DLL search order exploitation opportunity
- Autorun Program — startup application exploitable by low-privilege users

3. Methodology

The assessment followed a structured three-phase VM lifecycle, aligned with industry best practices from NIST SP 800-40 and the Qualys VMDR framework. Each phase builds upon the previous to demonstrate the compounding value of authenticated, verified vulnerability management.

Phase	Scan Type	Objective	Auth Method
Phase 1	Unauthenticated Scan	Establish baseline — network-visible exposure only	None (NULL session)

Phase 2	Authenticated Scan	Full internal visibility — packages, services, registry, OS patches	Windows: qualys_vulmgt_WINacc Linux: qualys_vulmgt_LINXacc + SSH key
Phase 3	Post-Hardening Verification	Confirm remediation effectiveness — validate fixed findings	Same credentials as Phase 2

3.1 Qualys Configuration

The following Qualys components were configured prior to scanning:

- Option Profile: 'Healthcare Center S.A (Windows & Linux VMs)' — Complete vulnerability detection, Windows and Unix SSH authentication enabled, full TCP port scan, standard UDP scan
- Authentication Records: Windows record using qualys_vulmgt_WINacc (Local Administrator); Unix/SSH record using qualys_vulmgt_LINXacc with SSH key pair and NOPASSWD sudo
- Scanner Appliance: KmoVulnScanLab (Scanner 15.0.1-1, Vulnerability Signatures 2.6.588-3)
- Scan titles followed a consistent naming convention to enable before/after comparison in VMDB dashboard

4. Scan Results — Phase Comparison

4.1 Ubuntu 24.04 LTS (192.168.75.132)

Metric	Phase 1 No-Auth	Phase 2 Auth	Phase 3 Post-Hardening	Change P2→P3
Total Vulnerabilities	18	90	89	−1 (−1.1%)
Confirmed	1	1	0	−1 ✓
Potential	3	1	1	0
Information Gathered	14	88	88	0
Security Risk (Avg)	4.0	4.0	4.0	No change

4.2 Windows Hosts Combined (192.168.75.129 + .130)

Metric	Phase 1 No-Auth	Phase 2 Auth	Phase 3 Post-Hardening	Change P2→P3
Total Vulnerabilities	54	706	587	−119 (−17%)
Confirmed	4	324	207	−117 (−36%)
Severity 5 (Urgent)	0	69	29	−40 (−58%)
Severity 4 (Critical)	0	159	106	−53 (−33%)
Security Risk (Avg)	3.0	5.0	5.0	Residual risk remains

Note: Phase 1 numbers for individual Windows hosts are approximated from the combined scan of both hosts (54 total). Phase 2 and 3 provide exact per-host data. The increase from Phase 1 to Phase 2 (+652 findings) demonstrates the critical value of credentialed scanning: 1,207% more findings visible with authentication.

5. Key Findings & Remediation

5.1 Remediated Findings (Verified by Rescan)

#	Finding	QID	Severity	Remediation Applied	Status
1	SMBv2 Signing Not Required	92094	3 — Serious (PCI)	Set-SmbServerConfiguration - RequireSecuritySignature \$true	Fixed ✓
2	SSH SHA-1 Deprecated MACs	38909	2 — Medium	Removed hmac-sha1* from sshd_config MACs directive	Fixed ✓
3	Windows Autorun Enabled	90012	1 — Minimal	Set CDRom Autorun=0; added NoDriveTypeAutoRun=0xFF	Fixed ✓
4	NoAutorun Registry Keys Missing	—	2 — Medium	Added NoAutorun=1 to HKLM Explorer policy key	Fixed ✓
5	Windows Security Updates (2024–2025)	Multiple	5 — Urgent	Installed KB5066791 + cumulative updates via PSWindowsUpdate	Partially Fixed
6	DACL Service Weak Permissions	—	High — LPE	Applied DENY Write ACL to daclservice.exe for BUILTIN\Users	Fixed ✓
7	File Permissions Service	—	High — LPE	Reset inheritance, granted Full Control to Admins/SYSTEM only	Fixed ✓
8	Insecure Registry Service	—	High — LPE	Applied sc sdset — removed FullControl for WD (Everyone)	Fixed ✓
9	Unquoted Service Path	105484	3 — Serious	Added quotes to binPath via sc.exe config unquotedsvc	Fixed ✓

5.2 VMDR Dashboard — Remediation Metrics

The Qualys VMDR Asset dashboard confirms remediation effectiveness through the 'Detections by Status' widget, showing Fixed vs. Active findings per host after the post-hardening scan:

Asset	Active	Fixed	New	Reopened	Criticality
ubuntu-server (192.168.75.132)	1	18	0	0	3
desktop-viur4ao (192.168.75.129)	119	43	0	0	3
win-rgjcdu4qtf2 (192.168.75.130)	85	77	0	0	3

6. Residual Risk & Recommendations

The following findings remain active after hardening. Each has been analyzed and classified by root cause, with a recommended remediation path for a production environment.

Finding	Host(s)	Severity	Root Cause	Recommended Action
EOL: Windows 10 22H2	Win10	5 — Urgent	OS reached end-of-life Oct 14, 2025. No further patches from Microsoft.	Upgrade to Windows 11 or Windows 10 LTSC. Isolate until upgrade.
Mozilla Firefox (outdated)	Both Windows	4–5	Firefox not updated during Windows Update cycle.	Deploy Firefox ESR via GPO or SCCM. Enforce auto-update policy.
VLC Media Player 1.1.0	Both Windows	3–5	Legacy VLC installed as part of lab. Not updated.	Uninstall or upgrade to latest VLC. Block via application allowlist.
AMD RYZENFALL/MASTERKEY	Ubuntu	4 — Potential	Hardware-level vulnerability in AMD Ryzen 7 5700G. No software patch.	Accepted risk — hardware replacement required. Mitigate with physical access controls.
OpenSSH CVEs (9.6p1)	Ubuntu	2–3 — Potential	OpenSSH <10.0 affected. Ubuntu 24.04 does not yet ship 10.x.	Vendor-managed (Canonical). Monitor Ubuntu Security Notices. Accept pending backport.
LPE Workshop Services	Win10	3 — Serious	Services remain registered in SCM even after ACL hardening.	Run sc.exe delete for each LPE service to fully remove from SCM.

7. SOP: Vulnerability Management Scanning Process

Document ID: SOP-VM-001 | Version: 1.0 | Owner: VM Team | Review Cycle: Annual

7.1 Purpose

This Standard Operating Procedure defines the repeatable process for executing authenticated vulnerability scans using Qualys VMDR, interpreting results, and initiating remediation workflows. It is designed to ensure consistency across the VM program and enable any qualified team member to execute scans independently.

7.2 Scope

Applicable to all assets enrolled in the Qualys VMDR platform, including Windows servers and workstations, and Linux servers. Excludes OT/SCADA systems and network devices unless specifically authorized.

7.3 Prerequisites

- Active Qualys VMDR subscription with Scanner Appliance deployed on target network
- Authentication records created for each OS type (Windows: local admin; Linux: SSH key + sudo NOPASSWD)
- Option Profile configured with Complete vulnerability detection and authentication enabled
- Target IP ranges defined and approved by change management
- Scanner appliance reachable from all target subnets (ports 135, 139, 445 for Windows; port 22 for Linux)

7.4 Procedure

Step 1 — Pre-Scan Validation

1. Verify scanner appliance status in Qualys: Scans > Appliances > confirm 'Active'
2. Confirm authentication records are valid: Assets > Authentication > test each record
3. Validate Option Profile settings: Windows and Unix/SSH authentication enabled, Complete detection
4. Confirm target IPs are in scope and change window is approved

Step 2 — Launch Scan

5. Navigate to Scans > New > Vulnerability Scan
6. Title the scan using naming convention: '[Asset Group] — [Scan Type] — [YYYY-MM-DD]'
7. Select Option Profile with authentication enabled
8. Enter target IPs or asset group
9. Select Scanner Appliance (internal scanner for internal assets)
10. Click Launch and note the scan reference number

Step 3 — Monitor & Validate

11. Monitor scan progress via Scans > Status
12. Verify QID 70028 (Windows Authentication Method) shows 'user-provided credentials' — not NULL session
13. Verify Linux hosts show 'Unix SSH authentication was successful'
14. If authentication fails: check firewall rules, Remote Registry service, and credential validity

Step 4 — Generate & Distribute Report

15. Navigate to Reports > New > Scan Report
16. Select completed scan, choose 'Detailed' template
17. Export as PDF and save with naming convention matching scan title
18. Distribute to asset owners and management per distribution matrix

Step 5 — Remediation Tracking

19. Create remediation tickets for all Severity 3–5 confirmed findings
20. Assign SLA based on severity: Sev 5 = 7 days, Sev 4 = 30 days, Sev 3 = 60 days
21. For non-patchable findings, initiate Risk Exception process (see SOP-VM-002)
22. Schedule verification scan upon remediation completion

7.5 SLA Targets

Severity	Label	Remediation SLA	Scan Frequency
5 — Urgent	Critical exploitable	7 days	Weekly
4 — Critical	Potential control loss	30 days	Bi-weekly
3 — Serious	Significant risk	60 days	Monthly
1–2 — Low/Medium	Informational/minor	90 days	Quarterly

8. Risk Exception Register

Document ID: SOP-VM-002 | Version: 1.0 | Owner: VM Team / Risk Owner | Review: Semi-Annual

Risk exceptions are formal acceptances of residual risk for findings that cannot be remediated within standard SLA due to technical, operational, or vendor constraints. Each exception requires documented justification, compensating controls, and a defined review date.

Exception #001 — EOL Operating System: Windows 10 22H2

QID	106307
Asset	DESKTOP-VIUR4AO (192.168.75.129)
Severity	5 — Urgent
Justification	Windows 10 22H2 reached end-of-life on October 14, 2025. This is a lab environment used for security training. OS upgrade is planned but outside current lab scope.
Compensating Controls	Host isolated on non-routed lab network; no internet access; no production data; network segmented from corporate environment.
Recommended Remediation	Upgrade to Windows 11 24H2 or Windows 10 LTSC 2021/2026. Enforce via Group Policy if domain-joined.
Risk Owner	Kendall Montero
Exception Expiry	October 23, 2026 — mandatory review
Status	APPROVED — Lab environment only

Exception #002 — AMD Processor Hardware Vulnerability (RYZENFALL/MASTERKEY)

QID	370876
Asset	ubuntu-server (192.168.75.132) — AMD Ryzen 7 5700G

CVEs	CVE-2018-8930, CVE-2018-8931, CVE-2018-8932, CVE-2018-8933, CVE-2018-8934, CVE-2018-8935, CVE-2018-8936
Severity	4 — Critical (Potential)
Justification	Hardware-level vulnerability in AMD Secure Processor. AMD has acknowledged these vulnerabilities but requires physical access to exploit. No firmware patch is available that fully remediates the underlying hardware design.
Compensating Controls	Physical access restricted to authorized lab personnel only. Host not accessible from external networks. Operating system and hypervisor patches applied to minimize software attack surface.
Recommended Remediation	Hardware replacement with non-affected processor family. In production, implement strict physical security controls and monitoring.
Risk Owner	Kendall Montero
Exception Expiry	April 23, 2027 — annual review
Status	APPROVED — Physical controls in place

Exception #003 — OpenSSH CVEs Pending Vendor Patch (Canonical)

QIDs	38919, 38979, 38999
Asset	ubuntu-server (192.168.75.132) — OpenSSH 9.6p1
CVEs	CVE-2023-51767, CVE-2025-32728, CVE-2025-61984
Severity	2–4 — Potential
Justification	Ubuntu 24.04 LTS ships OpenSSH 9.6p1. The fixed version (10.0+) is not yet available in Ubuntu Noble (24.04) official repositories. Canonical manages security backports independently of upstream version numbers.
Compensating Controls	SHA-1 deprecated algorithms removed from sshd_config (QID 38909 resolved). SSH access restricted to key-based authentication. SSH port not exposed beyond lab network.
Recommended Remediation	Monitor Ubuntu Security Notices (USN) for OpenSSH backport. Apply sudo apt upgrade openssh-server when patch is published by Canonical.
Risk Owner	Kendall Montero
Exception Expiry	October 23, 2026 — review when Canonical publishes patch
Status	APPROVED — Vendor managed, compensating controls active

9. Executive Brief: Why Vulnerability Management Matters

9.1 The Business Case

Vulnerability management is not a technical exercise — it is a business risk reduction program. Unpatched systems are the leading initial access vector in cybersecurity incidents. According to the Verizon DBIR, exploitation of known vulnerabilities accounts for a significant portion of breaches, the majority of which have patches available at the time of exploitation.

The core value proposition of a VM program is simple: you cannot fix what you cannot see. This lab demonstrated that without authenticated scanning, only 54 vulnerabilities were visible across two Windows hosts. With authentication, 706 vulnerabilities became visible — a 1,207% increase in true risk visibility. Of those, 119 were remediated in a single hardening cycle, verified by a subsequent scan.

9.2 Why Authenticated Scanning is Non-Negotiable

Unauthenticated Scan	Authenticated Scan
Sees only network-exposed services and banners	Sees installed software, patch levels, registry, services, and configurations
Cannot detect missing OS patches	Enumerates all installed KBs and identifies gaps
Cannot detect local privilege escalation vectors	Detects weak service permissions, unquoted paths, registry misconfigs
54 findings on Windows (this lab)	706 findings on Windows (this lab) — 13x more visibility

9.3 Framework Alignment

A mature VM program aligns with the following industry frameworks and standards:

Framework	VM Alignment
NIST CSF 2.0	Identify (ID.RA): Asset vulnerability identification; Protect (PR.IP): Patch management processes
NIST SP 800-40	Guide to Enterprise Patch Management — defines scanning frequency, SLAs, and remediation workflows
ISO/IEC 27001	Annex A.8.8: Management of technical vulnerabilities — requires systematic identification and remediation
PCI DSS v4.0	Requirement 6.3: Vulnerability identification and management; authenticated internal scans required quarterly
CIS Controls v8	Control 7: Continuous Vulnerability Management — credentialed scans, prioritization by CVSS/severity

9.4 VM Program Maturity Model

Organizations typically progress through four levels of VM maturity. This lab exercise demonstrates capabilities spanning Levels 1 through 3:

Level	Maturity Stage	Characteristics	This Lab
-------	----------------	-----------------	----------

1	Initial	Ad-hoc scanning, no authentication, limited visibility	Phase 1 — No-auth scan
2	Managed	Authenticated scanning, consistent process, defined SLAs	Phase 2 — Auth scan + SOP
3	Defined	Remediation tracking, exception management, verified rescans	Phase 3 — Hardening + rescan + exceptions
4	Optimized	Continuous monitoring, risk-based prioritization, automated ticketing, executive dashboards	Next maturity target

10. Conclusion

This lab exercise successfully demonstrated a complete, end-to-end Vulnerability Management lifecycle across a heterogeneous environment of Linux and Windows systems. The three-phase approach — unauthenticated baseline, authenticated discovery, and post-hardening verification — produced measurable, verifiable results documented in Qualys VMDR.

The most significant demonstration was the value of credentialed scanning: moving from 54 to 706 visible vulnerabilities on Windows hosts by enabling authentication — a 1,207% increase in risk visibility that would be invisible to perimeter-only scanning tools. This directly supports the business case for a mature, authenticated VM program in any organization subject to compliance requirements or operating in threat-relevant environments.

Remediation actions reduced confirmed Windows findings by 36% in a single cycle, with all actions verified by a subsequent authenticated scan. Residual findings have been formally documented through the Risk Exception Register with compensating controls and defined review dates — reflecting the operational reality that not all vulnerabilities can be patched immediately, and that documented risk acceptance is preferable to untracked exposure.

The SOPs and exception management framework included in this document are designed to be repeatable and scalable, enabling any VM program to operate consistently regardless of team size or tooling.

End of Report — Kendall Montero — April 23, 2026 — Confidential